

Модель нарушителей и модель угроз

22 сентября 2026

1 Роли

Роботы (участники) $P = \{1, \dots, N\}$, каждый держит приватное значение x_i (non-conformity score, дельта весов и т. п.).

Домохозяйства $H_1, \dots, H_m$ — непересекающиеся группы роботов, $P = \bigsqcup_j H_j$ (см. документ 06, раздел про compartmented secret sharing).

Сервер(а) Один сервер S (разделы 1–3 документа 06) или несколько $S_1, \dots, S_k$ (Механизм 4, multi-server). $S \cap P = \emptyset$ всегда.

Внешний наблюдатель Не участвует в протоколе; видит только выходы развёрнутой политики (действия робота) — релевантен основному security-роадмапу (membership inference, реконструкция), не MPC-слою напрямую.

Дилер Сторона, устанавливающая начальные PRF-ключи / доли на этапе настройки протокола (может быть распределённым процессом, не обязательно отдельным лицом).

2 Активы

- **Защищаем:** индивидуальное значение x_i каждого робота; принадлежность робота к домохозяйству (опционально, ниже приоритет).
- **Не защищаем по дизайну:** сам агрегат $\sum_i x_i$ — сервер обязан его узнать, это цель протокола, а не утечка.

3 Классы противника

A1. Honest-but-curious единственный сервер. Строго следует протоколу, но пытается извлечь больше, чем положено, из того, что видит. Базовая модель для PRSS/Bonawitz (документ 06, Механизм 1).

A2. Malicious единственный сервер. Отклоняется от протокола: например, в threshold-HE применяет ключ к *индивидуальному* c_i вместо агрегата, или подделывает сообщение об отвалившемся участнике, чтобы получить лишние доли. Требуется verifiability, а не только маскирования (документ 06, раздел «PRSS и Paillier совместно»).

A3. Сговор $< t$ участников. По определению порога схемы им не полагается узнать ничего — это не угроза, а формальная граница корректности схемы.

- A4. Сговор $\geq t$ независимых участников.** Успешная атака по построению схемы — параметр риска, управляемый выбором t , а не баг протокола.
- A5. Домохозяйственная коалиция.** Несколько роботов одного дома формально независимы по сырому счёту $|S|$, но фактически — один источник доверия (общий Wi-Fi, общий владелец). Наивный (t, N) -Shamir этого не учитывает; описано через домохозяйственный след $h(S)$ (документ 06, Механизм 3).
- A6. Byzantine-робот.** Не honest-but-curious — активно шлёт испорченное x_i (data poisoning) при формально корректном соблюдении MPC-протокола (доли/маски валидны, содержимое — нет). Secure aggregation сама по себе это не ловит; нужен отдельный слой (FedGT/group testing, документ 06, «Направление улучшения»).
- A7. Сговор серверов (multi-server, Механизм 4).** При m серверах приватность держится, пока число сговорившихся серверов меньше порога (1 из 2 у Prio, честное большинство у ABY3-стиля). Сговор всех m серверов ломает защиту полностью — фундаментальное ограничение модели, не инженерный дефект.
- A8. Злонамеренный дилер.** Компрометация этапа установки PRF-ключей/ долей ломает все последующие раунды. Verifiable-схемы (документ 06) защищают именно от этого класса.

4 Формальное условие нарушения приватности

Механизм	Условие успешной атаки
Single-server PRSS/Shamir	$ S_{\text{colluding}} \geq t$
Single-server + домохозяйства	$h(S_{\text{colluding}}) \geq \tau$ (число домохозяйств, не сырое число роботов)
Threshold-HE без маски	$\geq t$ участников сговариваются и применяют ключ к индивидуальному c_i , а не к агрегату
Threshold-HE + PRSS-маска	то же самое, но расшифровка отдельного c_i даёт $x_i + z_i$, не x_i — атака не даёт результата без дополнительного взлома PRF-структуры
Multi-server (Prio/ABY3)	сговор всех m серверов (или превышение порога честного большинства)
Byzantine-детекция отсутствует	1 испорченный робот не пойман FedGT-style механизмом

5 Обязательства участников (что должно происходить, чтобы гарантия держалась)

Роботы

- Честно участвовать в первоначальной генерации PRF-ключей/долей на этапе настройки — без verifiable-схемы это не проверяется автоматически, только с ней (VSS).
- Никогда не публиковать свою долю/ключ вне защищённого канала к серверу(ам).

- Использовать настоящие значения x_i , не сфабрикованные. **Это не гарантируется криптографией самого MPC-слоя** — требует отдельного byzantine-детектора (FedGT-style, документ 06).

Сервер(а)

- Не пытаться обрабатывать индивидуальные вклады отдельно от агрегата, даже если это технически возможно (см. A2) — отклонение от протокола, а не легальная операция.
- В multi-server модели — быть реально независимыми организациями. Несколько серверов одного вендора в разных дата-центрах **не** создают настоящую non-collusion (документ 06, Механизм 4).

Оператор системы

- Осознанно выбрать параметры: порог t , домохозяйственный порог τ , число серверов m — исходя из реалистичной оценки, сколько роботов/серверов может быть одновременно скомпрометировано, а не произвольно.
- Явно решить, нужна ли verifiability (VSS) — то есть учитывается ли класс A2/A8 (malicious сервер/дилер) в модели угроз, или ограничиваемся honest-but-curious (A1).

6 Явно вне рамок этого документа

Атаки класса «внешний наблюдатель» (membership inference, реконструкция обучающих данных по выходам развёрнутой политики) — предмет основного security-роадмапа проекта (*Your Robot Remembers Your Home*), не MPC-слоя. Этот документ формализует только угрозы внутри protocol'a агрегации.